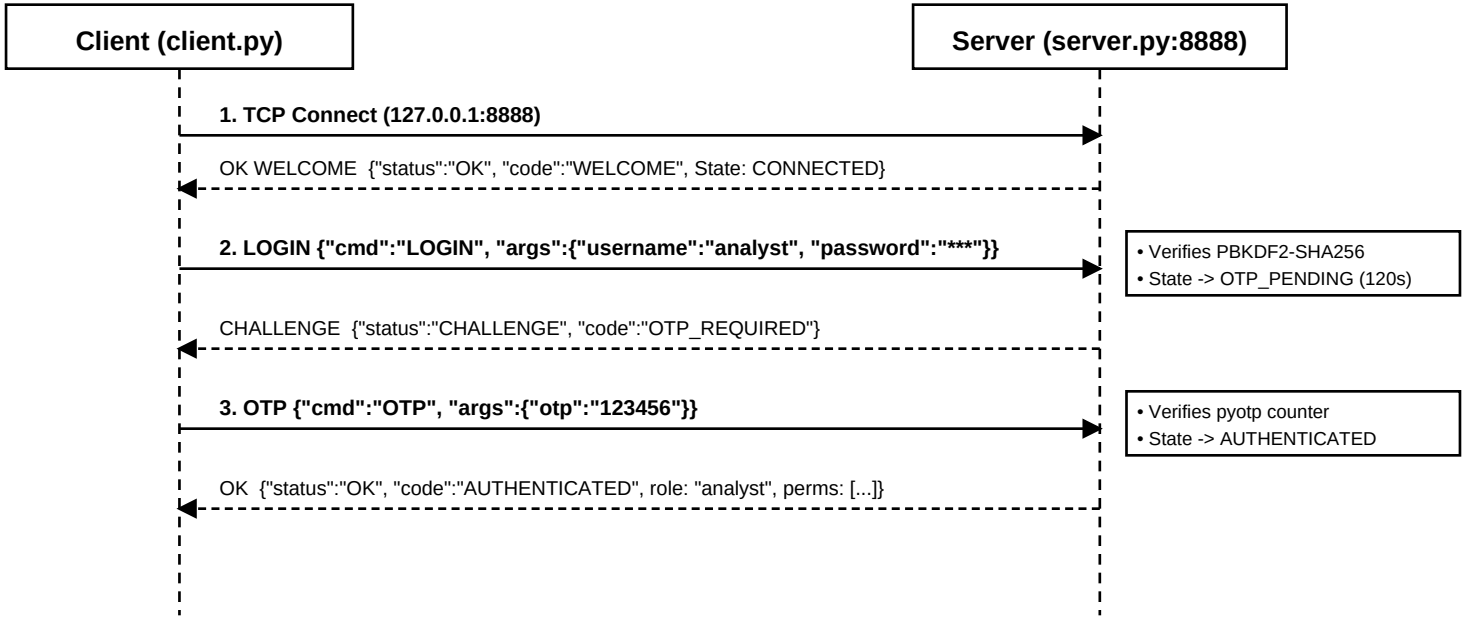
Figure C.1: Two-Factor Authentication (Password + TOTP) Protocol Sequence



Enforced Protocol Security Rules (server.py & client.py):

1. Strict Step Order: Submitting OTP before LOGIN returns ERROR AUTH_SEQUENCE (RFC 4226 / NIST SP 800-63B).
2. Pending Timeout: If OTP is not received within 120s (OTP_PENDING_TTL_S), pending state expires and drops to CONNECTED.
3. Replay Protection: consume_otp_counter() records used intervals in users.json to block replayed OTP frames.